



NEXO TALENTOS

AUDITORÍA TÉCNICA Y DE SEGURIDAD EXHAUSTIVA

Escaneo completo de la codebase enfocada en seguridad cliente, arquitectura de código y vectores de vulnerabilidad.

CRÍTICO 1. Exposición de Claves de API en el Bundle del Cliente

Hallazgo: Las llamadas a la API de Inteligencia Artificial (Gemini) se realizan directamente desde los componentes del navegador cliente. Esto implica que la API Key (VITE_GEMINI_API_KEY) queda incrustada en el código JavaScript empaquetado. Cualquier usuario o bot puede extraer la clave inspeccionando el código fuente y agotar las cuotas o generar costos no autorizados.

Recomendación: Migrar la interacción con Gemini a un Backend-for-Frontend (BFF) o Vercel Edge Function que actúe como proxy seguro sin exponer la clave en el frontend.

CRÍTICO 2. Inyección de Prompts y Ausencia de Sanitización HTML

Hallazgo: En los módulos de *CV Analyzer* y *Job Spec Generator*, los textos pegados por el usuario se concatenan directamente a los prompts enviados a la IA. Un usuario malintencionado podría realizar un ataque de *Prompt Injection*. Además, las respuestas devueltas no cuentan con sanitización estricta (DOMPurify) antes de renderizarse.

Recomendación: Escapar entradas de usuario y validar las respuestas devueltas mediante bibliotecas de sanitización DOM antes de inyectarlas.

ADVERTENCIA 3. Ausencia de Cabeceras HTTP de Seguridad (CSP / CORS)

Hallazgo: No se han definido cabeceras Content-Security-Policy (CSP), X-Frame-Options ni X-Content-Type-Options en el archivo de configuración de Vercel. Esto expone el sitio a ataques de *Clickjacking* o carga no autorizada de scripts de terceros.

ADVERTENCIA 4. Carencia de Rate Limiting y Protección Anti-Bots

Hallazgo: Al no existir autenticación ni rate limiting en el cliente, scripts automatizados pueden enviar peticiones masivas al chat de NexIA, saturando la experiencia y generando bloqueos de tasa por parte del proveedor de IA.

OK 5. Rendimiento Web Vitals y Code-Splitting

Hallazgo: Se han optimizado las imágenes a WebP/AVIF y fragmentado los bundles JS con React . lazy. Las métricas de SEO, Accesibilidad y Best Practices se encuentran en el 100%.